

CCSP

Certified Cloud Security Professional

300 Interview Questions & Answers

With Real-World Examples & Explanations

Akhilesh Chaudhari
Senior IT Engineer | akhileshchaudhari.com

Table of Contents

Domain 1	Cloud Concepts, Architecture & Design	Q1-Q50
Domain 2	Cloud Data Security	Q51-Q100
Domain 3	Cloud Platform & Infrastructure Security	Q101-Q150
Domain 4	Cloud Application Security	Q151-Q200
Domain 5	Cloud Security Operations	Q201-Q250
Domain 6	Legal, Risk & Compliance	Q251-Q300

Domain 1: Cloud Concepts, Architecture & Design

Q1. What is Cloud Computing?

Answer: Cloud computing is the delivery of computing services—including servers, storage, databases, networking, software—over the internet ('the cloud') to offer faster innovation, flexible resources, and economies of scale.

Example: AWS, Azure, and GCP provide on-demand compute resources so companies avoid buying physical servers.

Q2. What are the three cloud service models?

Answer: IaaS (Infrastructure as a Service), PaaS (Platform as a Service), and SaaS (Software as a Service). IaaS provides raw infrastructure, PaaS provides a development platform, SaaS provides ready-to-use applications.

Example: AWS EC2 is IaaS, AWS Elastic Beanstalk is PaaS, and Gmail is SaaS.

Q3. What are the four cloud deployment models?

Answer: Public cloud (shared infrastructure managed by provider), Private cloud (dedicated to one organisation), Community cloud (shared among organisations with common concerns), and Hybrid cloud (combination of two or more models).

Example: A bank uses a private cloud for sensitive data and public cloud for its public-facing website.

Q4. What is the Shared Responsibility Model?

Answer: In cloud computing, security responsibilities are divided between the cloud provider and the customer. The provider secures the underlying infrastructure; the customer secures data, identities, and configurations.

Example: AWS secures physical data centres; the customer is responsible for encrypting their S3 bucket data.

Q5. Define NIST's five essential cloud characteristics.

Answer: On-demand self-service, Broad network access, Resource pooling, Rapid elasticity, and Measured service. These characteristics distinguish true cloud from traditional hosting.

Example: A startup spins up 100 servers in minutes (rapid elasticity) and pays only for hours used (measured service).

Q6. What is multi-tenancy in cloud computing?

Answer: Multiple customers share the same physical infrastructure or software instances while being logically isolated from each other. This optimises resource use but introduces data segregation concerns.

Example: Several companies share the same physical Azure SQL server but their databases are isolated.

Q7. What is cloud sprawl and how can it be managed?

Answer: Cloud sprawl is the uncontrolled proliferation of cloud resources, leading to wasted spend and security gaps. It is managed via tagging policies, cloud governance frameworks, and regular audits.

Example: A company finds 200 unused EC2 instances after implementing a tagging and auto-shutdown policy.

Q8. Explain the concept of elasticity vs scalability.

Answer: Elasticity is the ability to automatically scale resources up or down based on demand in real time. Scalability is the capability of a system to handle increased load by adding resources, but not necessarily automatically.

Example: Auto Scaling Groups in AWS demonstrate elasticity by adding EC2 instances during traffic spikes.

Q9. What is a Virtual Machine (VM) and how does it relate to cloud?

Answer: A VM is a software emulation of a physical computer that runs an OS and applications. Cloud providers use hypervisors to host multiple VMs on single physical hosts, forming the basis of IaaS.

Example: An Azure Virtual Machine runs Windows Server on shared physical hardware.

Q10. What is containerisation and how does it differ from virtualisation?

Answer: Containers package application code with dependencies but share the host OS kernel, making them lighter than VMs which virtualise entire operating systems. Containers start faster and use fewer resources.

Example: Docker containers run microservices on Kubernetes clusters more efficiently than VM-per-service models.

Q11. What is serverless computing?

Answer: Serverless computing lets developers run code without managing servers. The cloud provider automatically provisions, scales, and manages infrastructure. Billing is per execution.

Example: AWS Lambda runs a function to resize images on S3 upload without any server management.

Q12. Define cloud bursting.

Answer: Cloud bursting is a configuration where an application runs in a private cloud but bursts into a public cloud when demand exceeds private capacity.

Example: A retailer's on-premise infrastructure handles normal traffic but bursts to AWS during Black Friday sales.

Q13. What is a Service Level Agreement (SLA) in cloud?

Answer: An SLA is a contract between cloud provider and customer defining expected service levels including uptime guarantees, performance benchmarks, and remedies for service failures.

Example: AWS EC2 SLA guarantees 99.99% monthly uptime; credits are issued if this is not met.

Q14. What is the Cloud Security Alliance (CSA)?

Answer: CSA is a non-profit organisation that promotes best practices for cloud security. It publishes the Cloud Controls Matrix (CCM) and the Security Guidance for Critical Areas of Focus in Cloud Computing.

Example: CCSP exam candidates study the CSA CCM to understand cloud security controls across domains.

Q15. Explain the concept of data residency.

Answer: Data residency refers to the physical or geographic location where an organisation's data is stored. Regulations like GDPR require data to remain within certain jurisdictions.

Example: A European company stores customer data only in AWS eu-west-1 (Ireland) to comply with GDPR.

Q16. What is a cloud broker?

Answer: A cloud broker is an intermediary that manages the use, performance, and delivery of cloud services and negotiates relationships between cloud providers and consumers.

Example: A company uses a cloud management platform as a broker to deploy workloads across AWS and Azure.

Q17. What is cloud portability?

Answer: Cloud portability is the ability to move applications and data between different cloud providers or between cloud and on-premises without significant re-engineering.

Example: Kubernetes enables workloads to run on both GCP and Azure with minimal configuration changes.

Q18. Define cloud interoperability.

Answer: Cloud interoperability is the ability of different cloud systems, services, and providers to work together through standard interfaces and data formats.

Example: An organisation uses OpenAPI standards so their AWS microservices communicate with Azure services.

Q19. What is vendor lock-in in cloud computing?

Answer: Vendor lock-in occurs when a customer becomes dependent on a single cloud provider's proprietary services, making migration to another provider difficult and costly.

Example: Relying solely on AWS Lambda and DynamoDB creates lock-in; using open standards like Kubernetes reduces it.

Q20. What is a Managed Service Provider (MSP) in cloud?

Answer: An MSP remotely manages a customer's cloud infrastructure and end-user systems. They handle monitoring, maintenance, security, and support.

Example: A small business outsources its Azure environment management to an MSP for 24/7 monitoring.

Q21. What is Infrastructure as Code (IaC)?

Answer: IaC is the practice of managing and provisioning computing infrastructure through machine-readable configuration files rather than manual processes.

Example: Terraform scripts provision entire AWS VPC environments reproducibly across multiple regions.

Q22. What is DevSecOps?

Answer: DevSecOps integrates security practices within the DevOps process, automating security checks throughout the CI/CD pipeline rather than treating security as a final gate.

Example: SAST tools in a Jenkins pipeline scan code for vulnerabilities on every commit.

Q23. What is a cloud-native application?

Answer: A cloud-native application is designed specifically to exploit cloud computing frameworks, using microservices, containers, dynamic orchestration, and CI/CD pipelines.

Example: Netflix runs its streaming service as hundreds of microservices on AWS, rebuilt from a monolith to cloud-native.

Q24. Explain the Twelve-Factor App methodology.

Answer: A methodology for building cloud-native SaaS apps with 12 best practices including codebase, dependencies, config, backing services, build/release/run, processes, port binding, concurrency, disposability, dev/prod parity, logs, and admin processes.

Example: A fintech startup builds their payment API following 12-factor principles for portability and scalability.

Q25. What is a microservices architecture?

Answer: Microservices architecture structures an application as a collection of small, independently deployable services each running its own process and communicating via

APIs.

Example: Amazon's e-commerce site uses separate microservices for cart, payment, recommendations, and search.

Q26. Define cloud orchestration.

Answer: Cloud orchestration automates the arrangement, coordination, and management of complex cloud systems and services to deliver a complete workflow or application.

Example: Kubernetes orchestrates Docker containers across a cluster, handling deployment, scaling, and self-healing.

Q27. What is a hypervisor?

Answer: A hypervisor (VMM) is software that creates and runs virtual machines by abstracting the underlying hardware. Type 1 runs on bare metal; Type 2 runs on a host OS.

Example: VMware ESXi (Type 1) runs multiple VMs on a single server in enterprise data centres.

Q28. Explain cloud storage types: block, file, and object.

Answer: Block storage provides raw volumes for databases (e.g., AWS EBS). File storage provides shared file systems (e.g., AWS EFS). Object storage stores unstructured data as objects with metadata (e.g., AWS S3).

Example: A MySQL database uses block storage; a web app serves static assets from object storage (S3).

Q29. What is Content Delivery Network (CDN) and its security role?

Answer: A CDN distributes content from edge servers geographically close to users, reducing latency. Security features include DDoS protection, WAF integration, and TLS termination.

Example: Cloudflare CDN serves website assets globally and blocks DDoS attacks before they reach the origin.

Q30. What is a Virtual Private Cloud (VPC)?

Answer: A VPC is a logically isolated section of a cloud provider's network where you can launch resources in a virtual network you define with control over IP ranges, subnets, and routing.

Example: An organisation creates an AWS VPC with public subnets for web servers and private subnets for databases.

Q31. What is cloud governance?

Answer: Cloud governance is the set of policies, processes, and controls that ensure cloud resources are used effectively, securely, and in compliance with regulations and business objectives.

Example: A company implements Azure Policy to enforce that all resources must be tagged with a cost centre.

Q32. What is a cloud access security broker (CASB)?

Answer: A CASB is a security policy enforcement point placed between cloud users and cloud services. It provides visibility, compliance, data security, and threat protection for cloud usage.

Example: A CASB like Microsoft Defender for Cloud Apps monitors SaaS usage and blocks unapproved apps.

Q33. Define the concept of zero-trust architecture in cloud.

Answer: Zero-trust assumes no user, device, or network is inherently trusted. Every access request is verified regardless of origin. It enforces least privilege, micro-segmentation, and continuous monitoring.

Example: Google's BeyondCorp model requires all employees to authenticate through identity-aware proxy regardless of network location.

Q34. What is cloud forensics?

Answer: Cloud forensics is the application of digital forensics techniques in cloud environments to investigate security incidents, preserve evidence, and support legal proceedings.

Example: Investigators pull AWS CloudTrail logs to reconstruct a data breach timeline after an incident.

Q35. What is a software-defined network (SDN)?

Answer: SDN separates the network control plane from the data plane, allowing programmable, centralised network management. In cloud, it enables dynamic network configuration and micro-segmentation.

Example: VMware NSX implements SDN in cloud to create micro-segmented networks between VMs.

Q36. What is edge computing and how does it relate to cloud?

Answer: Edge computing processes data closer to where it is generated (at the 'edge') rather than in a centralised cloud, reducing latency. It complements cloud by pre-processing data locally.

Example: IoT sensors in a factory process data at an edge device; only aggregated results go to the cloud.

Q37. What is a Service Mesh?

Answer: A service mesh is a dedicated infrastructure layer for handling service-to-service communication in microservices. It provides traffic management, observability, and security (mTLS).

Example: Istio implements a service mesh in Kubernetes, enforcing mTLS between all microservices.

Q38. Define cloud risk management.

Answer: Cloud risk management is the process of identifying, assessing, and mitigating risks associated with cloud adoption, including data loss, outages, compliance failures, and vendor risks.

Example: A bank performs a risk assessment before migrating core banking to AWS and implements compensating controls.

Q39. What is the Cloud Controls Matrix (CCM)?

Answer: The CSA CCM is a cybersecurity control framework specifically designed for cloud computing. It maps controls to major standards like ISO 27001, NIST, and PCI DSS.

Example: A SaaS company maps its AWS security controls to CSA CCM to demonstrate compliance to customers.

Q40. What is cloud cost optimisation?

Answer: Cloud cost optimisation involves right-sizing resources, using reserved/spot instances, eliminating waste, and implementing governance policies to reduce cloud spending.

Example: AWS Trusted Advisor identifies idle EC2 instances; switching to Reserved Instances saves 40%.

Q41. What is a distributed denial-of-service (DDoS) attack in cloud context?

Answer: A DDoS attack overwhelms cloud services with traffic from multiple sources to make them unavailable. Cloud providers offer DDoS protection services (e.g., AWS Shield, Azure DDoS Protection).

Example: A gaming company uses AWS Shield Advanced to absorb a 2 Tbps DDoS attack during a game launch.

Q42. What is a cloud migration strategy (6 Rs)?

Answer: The 6 Rs are: Rehost (lift-and-shift), Replatform, Repurchase, Refactor, Retire, and Retain. They represent different levels of transformation when moving to cloud.

Example: A company rehosted its web servers to AWS EC2 with no code changes, then refactored its database to RDS.

Q43. What is a multicloud strategy?

Answer: Multicloud is using multiple cloud providers for different services based on each provider's strengths, rather than relying on one provider for everything.

Example: An organisation uses GCP for ML/AI workloads, AWS for compute, and Azure for Active Directory integration.

Q44. What is cloud auditing?

Answer: Cloud auditing is the examination of cloud controls, processes, and logs to verify compliance with policies, regulations, and security requirements.

Example: An external auditor reviews AWS CloudTrail and Config records to assess SOC 2 compliance.

Q45. What is the principle of least privilege in cloud?

Answer: Least privilege means granting users, applications, and systems only the minimum permissions required to perform their functions, reducing the attack surface.

Example: An AWS Lambda function only has S3 read access to a specific bucket, not full S3 access.

Q46. What is Identity Federation in cloud?

Answer: Identity federation allows users to authenticate once with their home identity provider (e.g., corporate AD) and gain access to cloud services using SAML, OAuth, or OIDC tokens.

Example: Employees log into AWS using their corporate Office 365 credentials via SAML federation with Azure AD.

Q47. Define cloud automation.

Answer: Cloud automation uses software tools to create repeatable processes for deploying, managing, and optimising cloud resources without manual intervention.

Example: AWS Systems Manager Automation runbooks automatically patch EC2 instances every Tuesday night.

Q48. What is a cloud security posture management (CSPM) tool?

Answer: CSPM tools continuously monitor cloud environments for misconfigurations, compliance violations, and security risks, providing visibility and automated remediation.

Example: Palo Alto Prisma Cloud scans AWS accounts for open S3 buckets and alerts the security team.

Q49. What is quantum computing's potential impact on cloud security?

Answer: Quantum computers could break current public-key encryption (RSA, ECC), threatening data confidentiality. Post-quantum cryptography standards are being developed to address this.

Example: NIST is standardising quantum-resistant algorithms like CRYSTALS-Kyber for future cloud security.

Q50. What is the difference between availability zone and region in cloud?

Answer: A region is a geographic area with multiple isolated data centres. An Availability Zone (AZ) is one or more discrete data centres within a region with independent power, cooling, and networking.

Example: AWS us-east-1 region has 6 AZs; deploying across 3 AZs ensures high availability.

Domain 2: Cloud Data Security

Q51. What is data classification in cloud?

Answer: Data classification categorises data by sensitivity (e.g., Public, Internal, Confidential, Restricted) to apply appropriate security controls based on risk.

Example: A hospital classifies patient records as 'Restricted' and applies encryption-at-rest and strict IAM policies.

Q52. What is data loss prevention (DLP)?

Answer: DLP is a strategy and set of technologies that detect and prevent unauthorised transmission of sensitive data outside organisational boundaries.

Example: Microsoft Purview DLP blocks employees from emailing documents containing credit card numbers.

Q53. What is encryption at rest?

Answer: Encryption at rest protects stored data by encrypting it on disk so that even if physical storage is compromised, the data remains unreadable without the encryption key.

Example: AWS RDS encrypts database storage using AES-256 with keys managed in AWS KMS.

Q54. What is encryption in transit?

Answer: Encryption in transit protects data as it moves across networks by using protocols like TLS/SSL to prevent interception and eavesdropping.

Example: All API calls to AWS services use HTTPS (TLS 1.2+) to encrypt data in transit.

Q55. What is data sovereignty?

Answer: Data sovereignty refers to the concept that data is subject to the laws and governance structures of the country in which it is located.

Example: A German company must store EU citizen data on servers within Germany to comply with GDPR data sovereignty requirements.

Q56. What is a Key Management System (KMS)?

Answer: A KMS provides centralised creation, management, and control of cryptographic keys used for data encryption across cloud services.

Example: AWS KMS manages encryption keys for S3, EBS, and RDS with automatic key rotation policies.

Q57. Explain data masking vs data tokenisation.

Answer: Data masking replaces sensitive data with fictitious but realistic data for testing. Tokenisation replaces sensitive data with a non-sensitive token that maps back to the

original via a secure lookup.

Example: Credit card numbers are tokenised in PCI DSS systems; test databases use masked data.

Q58. What is a data lifecycle in cloud?

Answer: The data lifecycle includes creation/collection, storage, use, sharing, archiving, and destruction. Security controls must be applied at each phase.

Example: A company archives S3 data to Glacier after 90 days and applies a deletion policy at 7 years per compliance requirements.

Q59. What is digital rights management (DRM) in cloud?

Answer: DRM technologies control access to digital content, enforcing usage policies such as preventing copying, printing, or forwarding sensitive documents.

Example: Microsoft Azure Information Protection applies DRM policies so only HR can open salary spreadsheets.

Q60. What is data deduplication?

Answer: Data deduplication eliminates duplicate copies of data to optimise storage. In cloud, it reduces storage costs but must be carefully secured to prevent cross-tenant data leakage.

Example: A backup solution uses deduplication to store 10 TB of data in only 2 TB of cloud storage.

Q61. What is data remanence?

Answer: Data remanence is the residual representation of data that remains after attempts to remove or erase it. In cloud, proper sanitisation methods must be used before returning storage.

Example: After an AWS EBS volume is deleted, proper overwriting ensures data is not recoverable.

Q62. What is secure data destruction in cloud?

Answer: Secure data destruction ensures that cloud-stored data is irrecoverably removed, which may involve cryptographic erasure (deleting keys), overwriting, or provider-certified destruction.

Example: A company uses AWS KMS key deletion to cryptographically erase all S3 data encrypted with that key.

Q63. What is cloud data archiving?

Answer: Data archiving moves infrequently accessed data to lower-cost, long-term storage while maintaining accessibility for compliance and audit purposes.

Example: AWS S3 Glacier stores 7-year financial records at \$0.004/GB/month, far cheaper than active storage.

Q64. What is a data audit trail?

Answer: A data audit trail is a chronological record of all operations performed on data, showing who accessed or modified it and when, supporting compliance and forensics.

Example: AWS CloudTrail records every S3 object access, creating an immutable audit trail for compliance.

Q65. What is differential privacy?

Answer: Differential privacy is a mathematical framework that allows statistical analysis of datasets while providing strong privacy guarantees, preventing identification of individual records.

Example: Apple uses differential privacy to collect iOS usage statistics without revealing individual user behaviour.

Q66. What is homomorphic encryption?

Answer: Homomorphic encryption allows computation on encrypted data without decrypting it, so cloud providers can process sensitive data without ever seeing the plaintext.

Example: A healthcare company runs ML analysis on encrypted patient data in the cloud without exposing PHI.

Q67. What is database activity monitoring (DAM)?

Answer: DAM monitors and audits database activity in real time to detect unauthorised access, SQL injection, and policy violations.

Example: IBM Guardium monitors an AWS RDS database and alerts on after-hours bulk data exports.

Q68. What is egress filtering in cloud?

Answer: Egress filtering controls outbound traffic from cloud environments to prevent data exfiltration, C2 communication, and unauthorised data transfers.

Example: AWS Network ACLs and WAF block outbound connections to known malicious IPs from EC2 instances.

Q69. Explain the concept of data in use protection.

Answer: Data in use protection secures data while it is being processed in memory, using technologies like Trusted Execution Environments (TEE) and Confidential Computing.

Example: Azure Confidential Computing uses Intel SGX enclaves to protect data during processing.

Q70. What is a data breach notification requirement?

Answer: Many regulations (GDPR, HIPAA) require organisations to notify regulators and/or affected individuals within a specific timeframe (e.g., 72 hours for GDPR) after discovering a data breach.

Example: After detecting an S3 bucket breach, a UK company notifies the ICO within 72 hours per GDPR Article 33.

Q71. What is cloud database security?

Answer: Cloud database security includes encryption at rest and in transit, IAM-based access control, auditing, activity monitoring, and vulnerability assessment of managed database services.

Example: AWS RDS enables Multi-AZ, encryption, IAM authentication, and parameter group hardening for a banking DB.

Q72. What is data aggregation risk in cloud?

Answer: Data aggregation risk occurs when combining multiple non-sensitive data sets creates sensitive information that reveals more than any individual piece would.

Example: Combining location, purchase, and browsing data can identify individuals even when each dataset alone is anonymised.

Q73. What is the difference between data owner and data custodian?

Answer: The data owner is the business entity responsible for defining data use and protection policies. The data custodian is the technical entity (e.g., IT) responsible for implementing and maintaining those controls.

Example: HR is the data owner of employee records; the cloud team is the custodian managing S3 bucket security.

Q74. What is field-level encryption?

Answer: Field-level encryption encrypts individual sensitive fields in a database record (e.g., SSN, credit card) rather than the entire database, providing granular protection.

Example: An e-commerce app encrypts only the CVV and card number fields, leaving the order history in plaintext.

Q75. What is bring your own key (BYOK) in cloud?

Answer: BYOK allows customers to generate and manage their own encryption keys in cloud services, maintaining greater control over data compared to provider-managed keys.

Example: A financial firm imports their own HSM-generated keys into AWS KMS using BYOK for regulatory compliance.

Q76. What is hold your own key (HYOK)?

Answer: HYOK extends BYOK by keeping the encryption key entirely on-premises, so the cloud provider never has access to the key, maximising customer control.

Example: A government agency uses HYOK with Microsoft Azure to ensure their encryption keys never leave their on-premises HSM.

Q77. What is a secure multi-party computation?

Answer: Secure multi-party computation allows multiple parties to jointly compute a function over their combined data without any party revealing their individual inputs.

Example: Banks collaboratively train a fraud detection model without sharing customer data with each other.

Q78. What is data minimisation?

Answer: Data minimisation means collecting and retaining only the data that is strictly necessary for the specified purpose, a core GDPR principle.

Example: A website collects only email and name for newsletter sign-up, not phone number or date of birth.

Q79. What is a privacy impact assessment (PIA)?

Answer: A PIA (also called DPIA under GDPR) is a systematic process to evaluate privacy risks of a new system or processing activity before implementation.

Example: Before launching a new HR analytics tool on Azure, a company conducts a DPIA to assess employee data risks.

Q80. What is searchable encryption?

Answer: Searchable encryption allows searching over encrypted data without decrypting it first, enabling privacy-preserving queries in cloud storage.

Example: A legal firm uses searchable encryption so lawyers can search encrypted case files in cloud without the provider seeing content.

Q81. What is cloud Information Rights Management (IRM)?

Answer: IRM extends DRM to business documents, controlling who can view, edit, print, or forward sensitive files regardless of where they are stored or shared.

Example: Azure IRM prevents a confidential merger document from being forwarded outside the organisation.

Q82. What is the concept of data flow mapping?

Answer: Data flow mapping documents how data moves through systems, across borders, and between parties, supporting compliance, risk assessment, and architecture reviews.

Example: A GDPR audit requires mapping how customer PII flows from the website through AWS to a third-party CRM.

Q83. What is crypto-shredding?

Answer: Crypto-shredding is the practice of deleting encryption keys to render encrypted data permanently unreadable, serving as a cloud-compatible alternative to physical data destruction.

Example: A company deletes its AWS KMS Customer Managed Key to effectively destroy millions of encrypted S3 objects.

Q84. What is column-level security in cloud databases?

Answer: Column-level security restricts database users from reading or writing specific columns containing sensitive data (e.g., salary, SSN) based on roles.

Example: Only HR managers can query the 'salary' column in AWS Redshift; other users get NULL values.

Q85. What is tokenisation vs encryption?

Answer: Encryption transforms data mathematically and is reversible with a key. Tokenisation replaces data with a random token; the mapping is stored in a token vault, completely separate from the token.

Example: PCI DSS implementations often use tokenisation for card numbers because tokens have no mathematical relationship to original data.

Q86. What is data quality management in cloud?

Answer: Data quality management ensures cloud data is accurate, complete, consistent, timely, and fit for purpose through validation rules, cleansing, and monitoring.

Example: AWS Glue DataBrew profiles and cleanses raw sales data before loading into Redshift for analytics.

Q87. What is a data catalogue?

Answer: A data catalogue is an inventory of data assets with metadata, lineage, and classification information, helping organisations discover, understand, and govern their cloud data.

Example: AWS Glue Data Catalog stores metadata about S3 datasets, enabling discovery and policy enforcement.

Q88. What is pseudonymisation under GDPR?

Answer: Pseudonymisation replaces directly identifying information with artificial identifiers (pseudonyms), reducing privacy risk while allowing data to be re-linked if needed with additional information.

Example: A research database replaces patient names with numeric IDs; the key is held separately under strict access controls.

Q89. What is data escrow in cloud?

Answer: Data escrow is an arrangement where a third party holds a copy of data or encryption keys to be released under specific conditions (e.g., provider insolvency).

Example: A SaaS customer negotiates a data escrow clause requiring monthly backups held by a neutral third party.

Q90. What is the concept of data gravity?

Answer: Data gravity refers to the tendency of applications, services, and other data to accumulate around large datasets, making data migration increasingly difficult as more services depend on it.

Example: A company's analytics platform migrated to AWS but data gravity kept the transactional database on-premises longer.

Q91. What is synthetic data in cloud?

Answer: Synthetic data is artificially generated data that mimics the statistical properties of real data, used for testing and ML training without privacy risks.

Example: A bank generates synthetic transaction data to train fraud detection models without using real customer data.

Q92. What is a trusted execution environment (TEE)?

Answer: A TEE is a secure area of a processor that guarantees code and data loaded inside are protected with respect to confidentiality and integrity, even from the host OS.

Example: Azure Confidential VMs use AMD SEV-SNP to create TEEs that protect data even from Microsoft's administrators.

Q93. What is zero-knowledge proof?

Answer: Zero-knowledge proof is a cryptographic method where one party proves knowledge of a value without revealing the value itself.

Example: A user proves they are over 18 to a cloud service without revealing their actual date of birth.

Q94. What is data provenance?

Answer: Data provenance tracks the origin, movement, and transformation history of data, providing an audit trail of where data came from and how it was processed.

Example: AWS Lake Formation records data lineage showing how raw IoT data was transformed into analytical reports.

Q95. What is a data processing agreement (DPA)?

Answer: A DPA is a legally binding contract between a data controller and data processor specifying obligations around data processing, required under GDPR Article 28.

Example: A company signs a DPA with AWS ensuring AWS processes EU customer data only per GDPR requirements.

Q96. What is information lifecycle management (ILM)?

Answer: ILM is a policy-driven approach to managing information through its entire lifecycle from creation to disposal, balancing accessibility, cost, and compliance.

Example: AWS S3 Lifecycle policies move data to Glacier after 30 days and delete it after 7 years per ILM policy.

Q97. What is shadow IT risk in cloud data security?

Answer: Shadow IT refers to unauthorised cloud services used by employees without IT approval, creating uncontrolled data exposure and compliance risks.

Example: Employees uploading company documents to personal Dropbox accounts bypass corporate DLP and encryption controls.

Q98. What is runtime application self-protection (RASP)?

Answer: RASP is a security technology built into an application that detects and prevents attacks in real time by monitoring application behaviour from within.

Example: A cloud-hosted web app uses RASP to block SQL injection attempts even if they bypass the WAF.

Q99. What is consent management in cloud data?

Answer: Consent management tracks and enforces user consent for data collection and processing, required by GDPR, CCPA, and similar regulations.

Example: A website uses an OneTrust consent management platform to record and honour user cookie preferences stored in AWS.

Q100. What is a data retention policy?

Answer: A data retention policy defines how long different types of data must be kept based on legal, regulatory, and business requirements, and procedures for secure disposal.

Example: A financial firm's policy retains trade records for 7 years in S3 Glacier, then auto-deletes via lifecycle rules.

Domain 3: Cloud Platform & Infrastructure Security

Q101. What is network segmentation in cloud?

Answer: Network segmentation divides a cloud network into isolated zones using VPCs, subnets, security groups, and NACLs to limit lateral movement during a breach.

Example: A three-tier web app separates web, application, and database tiers into separate subnets with restrictive security groups.

Q102. What is a bastion host (jump server)?

Answer: A bastion host is a hardened server that provides secure access to private cloud resources. Administrators SSH/RDP to the bastion first, then hop to internal servers.

Example: Administrators connect to private AWS EC2 instances only through a bastion host in a public subnet.

Q103. What is a Web Application Firewall (WAF)?

Answer: A WAF monitors, filters, and blocks HTTP traffic to/from a web application based on defined rules, protecting against OWASP Top 10 attacks like SQLi and XSS.

Example: AWS WAF protects an API Gateway by blocking requests with SQL injection patterns.

Q104. What is cloud workload protection platform (CWPP)?

Answer: CWPP provides security for cloud workloads including VMs, containers, and serverless functions, covering vulnerability management, runtime protection, and compliance.

Example: Qualys CWPP scans Kubernetes pods for CVEs and detects runtime anomalies in containerised applications.

Q105. What is a Security Group vs Network ACL in AWS?

Answer: Security Groups are stateful firewalls at the instance level; NACLs are stateless firewalls at the subnet level. Security Groups allow traffic by default; NACLs can explicitly deny.

Example: A security group allows only port 443 to a web server; a NACL blocks a specific malicious IP range at the subnet level.

Q106. What is host-based intrusion detection (HIDS)?

Answer: HIDS monitors activity on individual cloud instances, detecting file changes, suspicious processes, and policy violations by analysing host logs and system calls.

Example: OSSEC deployed on EC2 instances alerts when /etc/passwd is modified or a rootkit is detected.

Q107. What is network intrusion detection system (NIDS) in cloud?

Answer: NIDS monitors network traffic across cloud environments for suspicious patterns and known attack signatures, providing alerts without blocking traffic.

Example: AWS VPC Traffic Mirroring sends traffic to a Suricata NIDS for deep packet inspection.

Q108. What is vulnerability scanning in cloud?

Answer: Vulnerability scanning automatically identifies known security weaknesses in cloud resources including OS patches, misconfigurations, open ports, and software CVEs.

Example: AWS Inspector automatically scans EC2 instances and ECR container images for CVEs and network exposure.

Q109. What is penetration testing in cloud?

Answer: Penetration testing simulates real-world attacks against cloud infrastructure to identify exploitable vulnerabilities before attackers do. Cloud providers have specific rules of engagement.

Example: A company conducts a pre-approved pentest of their AWS environment following AWS's penetration testing policy.

Q110. What is a honeypot in cloud security?

Answer: A honeypot is a decoy system designed to attract attackers, detect intrusion attempts, and gather intelligence about attack techniques without risking production systems.

Example: A cloud honeypot mimics an unprotected S3 bucket; any access triggers an immediate alert to the security team.

Q111. What is secure boot in cloud VMs?

Answer: Secure boot ensures that only cryptographically signed and trusted bootloaders and OS kernels are loaded, preventing rootkits and boot-level malware.

Example: GCP Shielded VMs use Secure Boot and vTPM to verify VM integrity from firmware through OS boot.

Q112. What is immutable infrastructure?

Answer: Immutable infrastructure means that cloud resources are never modified after deployment; updates are made by replacing the entire resource with a new image.

Example: Blue-green deployments replace old EC2 AMIs with new ones rather than patching running instances.

Q113. What is configuration management in cloud security?

Answer: Configuration management ensures cloud resources are configured securely and consistently through automated tools, drift detection, and compliance checking.

Example: AWS Config detects when an S3 bucket's public access is enabled and triggers an auto-remediation Lambda.

Q114. What is a Security Information and Event Management (SIEM) system?

Answer: A SIEM aggregates, correlates, and analyses security logs from across cloud environments to detect threats, support investigations, and meet compliance requirements.

Example: Splunk ingests AWS CloudTrail, VPC Flow Logs, and GuardDuty findings to detect cross-account enumeration.

Q115. What is cloud endpoint security?

Answer: Cloud endpoint security protects devices accessing cloud resources through EDR solutions, mobile device management, and conditional access policies.

Example: Microsoft Intune enforces that only compliant corporate devices can access Azure applications.

Q116. What is a privileged access workstation (PAW)?

Answer: A PAW is a dedicated, hardened computer used exclusively for privileged administrative tasks, reducing the risk of credential theft during admin activities.

Example: Cloud admins use PAWs to access AWS console, isolated from their regular workstations used for email.

Q117. What is just-in-time (JIT) access in cloud?

Answer: JIT access grants privileged access only for the duration needed for a specific task, automatically revoking it afterward to reduce standing privilege exposure.

Example: Azure PIM grants a security engineer temporary owner access to an Azure subscription for a 4-hour maintenance window.

Q118. What is patch management in cloud?

Answer: Patch management ensures cloud operating systems, middleware, and applications are updated with security patches in a timely, tested manner.

Example: AWS Systems Manager Patch Manager automatically applies critical OS patches to EC2 instances within 24 hours.

Q119. What is container security?

Answer: Container security covers securing container images (no vulnerabilities, least privilege), runtime protection, secrets management, and network policies between containers.

Example: Snyk scans Docker images in CI/CD pipeline; Kubernetes NetworkPolicy restricts pod-to-pod communication.

Q120. What is Kubernetes RBAC?

Answer: Kubernetes Role-Based Access Control restricts which users or service accounts can perform which actions on which resources within Kubernetes clusters.

Example: A developer's service account has only 'get' and 'list' on pods in their namespace, not 'delete' or 'exec'.

Q121. What is a pod security policy (PSP)/Pod Security Admission?

Answer: Pod Security Admission (replaced PSP in K8s 1.25) controls security-sensitive aspects of pod specification, preventing privileged containers, host network access, etc.

Example: Pod Security Admission in 'restricted' mode prevents pods from running as root in production namespace.

Q122. What is secrets management in cloud?

Answer: Secrets management securely stores, accesses, and rotates credentials, API keys, certificates, and other secrets used by applications and infrastructure.

Example: HashiCorp Vault or AWS Secrets Manager stores DB passwords and rotates them automatically every 30 days.

Q123. What is network flow logging?

Answer: Network flow logs capture metadata about network traffic in cloud environments (source/destination IP, port, protocol, bytes) supporting security analysis without packet capture.

Example: AWS VPC Flow Logs detect unusual outbound traffic suggesting data exfiltration from a compromised EC2 instance.

Q124. What is cloud security benchmarking?

Answer: Cloud security benchmarking compares cloud configurations against established standards like CIS Benchmarks to identify security gaps.

Example: AWS Security Hub runs CIS AWS Foundations Benchmark checks and reports deviations with remediation guidance.

Q125. What is a cloud firewall vs an on-premises firewall?

Answer: Cloud firewalls are software-defined, scalable, and managed via APIs; they integrate with cloud-native services. On-premises firewalls are hardware-based with manual configuration and fixed capacity.

Example: AWS Network Firewall scales automatically and inspects traffic between VPCs, replacing static on-premises appliances.

Q126. What is supply chain security in cloud?

Answer: Supply chain security ensures the software, containers, and dependencies used in cloud workloads come from trusted sources and have not been tampered with.

Example: Sigstore cosign verifies cryptographic signatures of container images before Kubernetes allows deployment.

Q127. What is a software bill of materials (SBOM)?

Answer: An SBOM is a formal list of all components, libraries, and dependencies in a software application, enabling vulnerability tracking and supply chain risk management.

Example: An SBOM for a cloud-deployed app reveals a vulnerable Log4j version, enabling rapid patching.

Q128. What is runtime security monitoring?

Answer: Runtime security monitoring detects threats to cloud workloads during execution, including anomalous system calls, unexpected network connections, and file integrity violations.

Example: Falco monitors Kubernetes pod system calls and alerts when a pod attempts to read /etc/shadow.

Q129. What is a cloud security architecture review?

Answer: A cloud security architecture review assesses whether a cloud design meets security requirements by examining network topology, IAM, encryption, logging, and resilience.

Example: A solutions architect reviews a three-tier AWS architecture against the AWS Well-Architected Security Pillar before go-live.

Q130. What is microsegmentation?

Answer: Microsegmentation applies granular security policies at the individual workload or application level, reducing lateral movement between services even within the same network zone.

Example: VMware NSX enforces microsegmentation between VMs in the same VLAN, preventing lateral spread of ransomware.

Q131. What is a cloud DMZ?

Answer: A cloud DMZ is a perimeter network segment that exposes selected services to untrusted networks while protecting the internal cloud network with additional security layers.

Example: Web servers in a public subnet (DMZ) communicate with application servers in a private subnet via tightly controlled security groups.

Q132. What is a private endpoint in cloud?

Answer: A private endpoint allows private connectivity to cloud services (e.g., S3, Azure Storage) from within a VNet/VPC without traversing the public internet.

Example: AWS PrivateLink creates a private endpoint for S3 so EC2 instances access S3 without leaving the AWS network.

Q133. What is TLS mutual authentication (mTLS)?

Answer: mTLS requires both client and server to present and verify certificates, providing bidirectional authentication. It is used in zero-trust and service mesh architectures.

Example: Istio service mesh enforces mTLS between all microservices in Kubernetes, verifying both caller and callee identity.

Q134. What is a hardware security module (HSM)?

Answer: An HSM is a physical or cloud-based device that generates, stores, and manages cryptographic keys in a tamper-resistant environment, meeting FIPS 140-2 Level 3 compliance.

Example: AWS CloudHSM provides a dedicated HSM for a bank needing FIPS 140-2 Level 3 key storage compliance.

Q135. What is security hardening?

Answer: Security hardening reduces the attack surface of systems by removing unnecessary services, changing defaults, applying patches, and implementing security controls.

Example: A CIS-hardened AMI for EC2 disables root SSH, removes unused packages, and configures auditd.

Q136. What is cloud intrusion prevention system (IPS)?

Answer: An IPS actively monitors and blocks malicious network traffic in real time, unlike IDS which only detects. Cloud IPS inspects traffic inline.

Example: AWS Network Firewall IPS rules block known exploit payloads targeting web servers in real time.

Q137. What is a cloud asset inventory?

Answer: A cloud asset inventory is a complete, up-to-date catalogue of all cloud resources (VMs, buckets, databases, IAM roles) for security visibility and governance.

Example: AWS Config continuously discovers and records all AWS resources, providing a full asset inventory.

Q138. What is threat modelling in cloud?

Answer: Threat modelling systematically identifies potential threats to a cloud architecture using frameworks like STRIDE, evaluating attack vectors, impacts, and mitigations.

Example: A team uses STRIDE to model threats to their AWS API Gateway, identifying spoofing and injection risks.

Q139. What is lateral movement in cloud attacks?

Answer: Lateral movement occurs when an attacker moves through a network after initial compromise, escalating privileges and accessing additional resources.

Example: After compromising an EC2 instance, an attacker uses its IAM role to enumerate and access S3 buckets.

Q140. What is credential stuffing in cloud context?

Answer: Credential stuffing uses stolen username/password combinations from data breaches to attempt logins to cloud management consoles and APIs.

Example: Attackers try 10 million leaked credentials against AWS IAM console login; MFA prevents account takeover.

Q141. What is server-side request forgery (SSRF) in cloud?

Answer: SSRF is an attack where the server is tricked into making requests to internal resources, in cloud it is often used to access the instance metadata service and steal credentials.

Example: Capital One breach exploited SSRF in a WAF to access AWS instance metadata and retrieve IAM credentials.

Q142. What is IMDSv2 and why is it important?

Answer: IMDSv2 is AWS's improved Instance Metadata Service requiring a session token, preventing SSRF attacks from stealing EC2 instance credentials via the metadata endpoint.

Example: Enforcing IMDSv2 via SCP prevents SSRF attacks from retrieving EC2 role credentials at 169.254.169.254.

Q143. What is cloud resource tagging for security?

Answer: Resource tagging applies metadata labels to cloud resources for security governance, cost allocation, compliance enforcement, and automated policy application.

Example: An SCP denies creation of any EC2 instance without mandatory tags: Environment, Owner, and CostCenter.

Q144. What is a security policy as code?

Answer: Security policy as code defines and enforces security controls programmatically using tools like OPA (Open Policy Agent), enabling automated, version-controlled policy management.

Example: OPA policies in Kubernetes admission control reject any pod not using approved container registries.

Q145. What is cloud security monitoring maturity?

Answer: Cloud security monitoring maturity measures the sophistication of an organisation's ability to detect, analyse, and respond to cloud security events across five maturity levels.

Example: An organisation progresses from basic CloudTrail alerting (level 1) to AI-driven threat hunting (level 5).

Q146. What is a deception technology in cloud?

Answer: Deception technology deploys fake assets (honeypots, honeytokens) across the cloud environment to detect attackers who access these decoys.

Example: Fake AWS access keys embedded in source code trigger alerts when an attacker tries to use them.

Q147. What is cloud encryption key rotation?

Answer: Key rotation periodically replaces encryption keys to limit the amount of data encrypted with any single key, reducing exposure from key compromise.

Example: AWS KMS automatically rotates CMKs annually; S3 objects are transparently re-encrypted with the new key version.

Q148. What is a cloud security incident response plan?

Answer: A cloud security incident response plan defines procedures for detecting, containing, eradicating, and recovering from cloud security incidents, with roles, communication, and escalation paths.

Example: The IR plan specifies that an AWS EC2 compromise triggers VPC isolation, memory snapshot, and CloudTrail preservation within 15 minutes.

Q149. What is a cloud disaster recovery plan?

Answer: A cloud disaster recovery plan defines how to restore critical systems and data after a disaster, specifying RTO, RPO, failover procedures, and testing schedules.

Example: A company's DR plan uses AWS Pilot Light in us-west-2 with RTO of 4 hours and RPO of 1 hour.

Q150. What is a recovery time objective (RTO) and recovery point objective (RPO)?

Answer: RTO is the maximum acceptable time to restore systems after a disruption. RPO is the maximum acceptable data loss measured in time.

Example: A bank's RTO is 1 hour and RPO is 15 minutes, requiring real-time replication and automated failover.

Domain 4: Cloud Application Security

Q151. What is the OWASP Top 10?

Answer: The OWASP Top 10 is a list of the ten most critical web application security risks including injection, broken authentication, XSS, insecure deserialization, and others, used as a baseline for web security.

Example: A cloud-hosted web app passes OWASP Top 10 testing before launch, including testing for SQL injection and CSRF.

Q152. What is SQL injection and how is it prevented?

Answer: SQL injection inserts malicious SQL into input fields to manipulate database queries. Prevention includes parameterised queries, ORMs, input validation, and WAF rules.

Example: An attacker enters ' OR 1=1-- into a login field; parameterised queries prevent the database from executing injected SQL.

Q153. What is Cross-Site Scripting (XSS)?

Answer: XSS allows attackers to inject malicious scripts into web pages viewed by other users, stealing cookies, session tokens, or performing actions on behalf of victims.

Example: A stored XSS payload in a cloud app's comment field steals admin session cookies; CSP headers prevent script execution.

Q154. What is Cross-Site Request Forgery (CSRF)?

Answer: CSRF tricks authenticated users into submitting malicious requests to a web application, exploiting the trust a site has in a user's browser.

Example: CSRF tokens in forms prevent attackers from tricking users into transferring funds on a banking app.

Q155. What is secure software development lifecycle (SSDL)?

Answer: SSDLC integrates security activities (threat modelling, code review, SAST, DAST, penetration testing) at every phase of software development.

Example: A cloud app team performs threat modelling in design, SAST in CI/CD, and DAST against staging before each release.

Q156. What is static application security testing (SAST)?

Answer: SAST analyses source code, bytecode, or binaries for security vulnerabilities without executing the application, catching issues early in development.

Example: Checkmarx SAST in a GitHub Actions pipeline flags hardcoded AWS credentials on every pull request.

Q157. What is dynamic application security testing (DAST)?

Answer: DAST tests running applications by simulating external attacks, finding runtime vulnerabilities like XSS, SQLi, and authentication flaws that SAST cannot.

Example: OWASP ZAP scans a staging AWS Elastic Beanstalk application for runtime vulnerabilities before production deployment.

Q158. What is software composition analysis (SCA)?

Answer: SCA identifies open-source components and third-party libraries in code, checking them against vulnerability databases (CVE) and licence compliance requirements.

Example: Snyk SCA in CI/CD detects a critical vulnerability in a npm package and blocks deployment until patched.

Q159. What is API security?

Answer: API security protects APIs from abuse through authentication (OAuth, API keys), authorisation (RBAC), rate limiting, input validation, and monitoring.

Example: AWS API Gateway enforces OAuth 2.0 JWT validation, rate limiting, and WAF protection for all API endpoints.

Q160. What is OAuth 2.0?

Answer: OAuth 2.0 is an authorisation framework allowing third-party applications to access resources on behalf of a user without sharing credentials, using access tokens.

Example: A mobile app uses OAuth 2.0 to access a user's Google Drive files; the user consents without sharing their Google password.

Q161. What is OpenID Connect (OIDC)?

Answer: OIDC is an identity layer on top of OAuth 2.0 that provides authentication, returning an ID token with user identity claims in addition to the access token.

Example: AWS Cognito uses OIDC to authenticate users and provide JWT ID tokens for downstream API authorisation.

Q162. What is JWT (JSON Web Token)?

Answer: JWT is a compact, self-contained token format for transmitting claims between parties as a JSON object, signed (JWS) or encrypted (JWE).

Example: An API gateway validates a JWT's signature and expiry before allowing access to a protected microservice.

Q163. What is broken access control?

Answer: Broken access control (OWASP #1) occurs when users can act outside their intended permissions, accessing others' data or performing unauthorised actions.

Example: A bug allows a regular user to access the admin dashboard by changing /user/123 to /admin/dashboard in the URL.

Q164. What is insecure direct object reference (IDOR)?

Answer: IDOR occurs when an application uses user-supplied input to access objects without proper authorisation checks, allowing users to access other users' data.

Example: Changing /api/invoice/1001 to /api/invoice/1002 exposes another customer's invoice due to missing authorisation check.

Q165. What is security misconfiguration in cloud apps?

Answer: Security misconfiguration includes improper settings like open S3 buckets, default credentials, verbose error messages, and unnecessary features enabled.

Example: A developer leaves an S3 bucket publicly readable; automated CSPM scans detect and alert on this misconfiguration.

Q166. What is the principle of defence in depth for applications?

Answer: Defence in depth layers multiple security controls so that if one control fails, others still protect the application. It combines WAF, RASP, input validation, and monitoring.

Example: A cloud app uses WAF + input validation + parameterised queries + RASP, so SQLi is blocked at multiple layers.

Q167. What is a CI/CD pipeline security?

Answer: CI/CD pipeline security integrates automated security checks (SAST, SCA, container scanning, secrets detection) into the build and deployment process.

Example: A Jenkins pipeline runs SAST, dependency scanning, and image signing before pushing to ECR and deploying to EKS.

Q168. What is container image hardening?

Answer: Container image hardening minimises the attack surface by using minimal base images, running as non-root, removing unnecessary tools, and scanning for CVEs.

Example: Using distroless images removes shell, package managers, and debugging tools, reducing attack surface by 80%.

Q169. What is secrets detection in source code?

Answer: Secrets detection scans source code and git history for accidentally committed credentials, API keys, and certificates before they reach production.

Example: GitGuardian detects an AWS access key committed to a public GitHub repo and immediately alerts the developer.

Q170. What is input validation in cloud applications?

Answer: Input validation ensures all data entered into an application is of the expected type, format, length, and range before processing, preventing injection attacks.

Example: A web form validates that a phone number contains only digits and is exactly 10 characters before sending to the backend.

Q171. What is output encoding?

Answer: Output encoding transforms special characters in output data to their encoded equivalents before rendering in HTML, preventing XSS attacks.

Example: Converting < to < before rendering user input in HTML prevents stored XSS script execution.

Q172. What is a secure API gateway design?

Answer: Secure API gateway design includes authentication, rate limiting, request/response validation, TLS enforcement, WAF integration, and comprehensive logging.

Example: AWS API Gateway with Cognito authoriser, usage plans (rate limits), request validation, and WAF provides layered API security.

Q173. What is the STRIDE threat model?

Answer: STRIDE categorises threats as Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege, used in application threat modelling.

Example: Threat modelling a payment API identifies Elevation of Privilege risk if JWT validation is skipped for internal calls.

Q174. What is insecure deserialisation?

Answer: Insecure deserialisation processes untrusted serialised data that can be manipulated to achieve remote code execution, replay attacks, or object injection.

Example: Java deserialization vulnerabilities in older Apache Struts allowed attackers to execute arbitrary code on servers.

Q175. What is a bug bounty programme?

Answer: A bug bounty programme rewards external security researchers for responsibly disclosing security vulnerabilities, supplementing internal security testing.

Example: HackerOne bug bounty programme pays researchers \$10,000 for critical RCE vulnerabilities in a cloud SaaS product.

Q176. What is application logging and monitoring for security?

Answer: Security-focused application logging captures authentication events, access control decisions, input validation failures, and errors, sending them to a centralised SIEM.

Example: AWS CloudWatch collects application logs; failed login attempts trigger GuardDuty and automated responses.

Q177. What is a web application firewall bypass?

Answer: WAF bypass techniques use encoding, obfuscation, or fragmentation to evade WAF rules. Defence requires regularly updating rules and using machine learning-based WAFs.

Example: An attacker uses URL encoding (%27 for ') to bypass a naive WAF rule; a next-gen WAF decodes before inspection.

Q178. What is security regression testing?

Answer: Security regression testing re-runs security tests after code changes to ensure previously fixed vulnerabilities have not been reintroduced.

Example: A DAST scan runs on every release to verify the SQLi fix from the previous sprint was not broken by new code.

Q179. What is content security policy (CSP)?

Answer: CSP is an HTTP response header that specifies which sources the browser should trust for scripts, styles, and other content, mitigating XSS attacks.

Example: CSP header 'script-src self' prevents a malicious CDN script injected via XSS from executing in the user's browser.

Q180. What is HTTP strict transport security (HSTS)?

Answer: HSTS instructs browsers to only connect to a site over HTTPS, preventing SSL stripping attacks and accidental HTTP connections.

Example: Setting 'Strict-Transport-Security: max-age=31536000; includeSubDomains' ensures all subdomains use HTTPS for one year.

Q181. What is clickjacking and how is it prevented?

Answer: Clickjacking embeds a site in an invisible iframe to trick users into clicking on concealed elements. Prevented by X-Frame-Options or CSP frame-ancestors header.

Example: X-Frame-Options: DENY prevents a bank's login page from being embedded in an attacker's iframe.

Q182. What is a server-side template injection (SSTI)?

Answer: SSTI occurs when user input is embedded in a server-side template without sanitisation, potentially allowing code execution on the server.

*Example: An attacker inputs {{7*7}} into a Jinja2 template field; seeing '49' confirms SSTI and further exploitation is possible.*

Q183. What is XML external entity (XXE) injection?

Answer: XXE exploits XML parsers that process external entity references, potentially exposing internal files or enabling SSRF.

Example: A cloud API accepting XML input disables external entity processing in the parser to prevent XXE file disclosure.

Q184. What is API rate limiting?

Answer: API rate limiting restricts the number of requests a client can make in a time period, preventing brute force, credential stuffing, and DoS attacks.

Example: AWS API Gateway usage plans limit an API key to 1000 requests per minute, blocking automated scraping attempts.

Q185. What is a replay attack in API security?

Answer: A replay attack captures a valid authentication token or signed request and resends it to gain unauthorised access or repeat transactions.

Example: Adding nonce and timestamp to HMAC-signed API requests and rejecting requests older than 5 minutes prevents replay attacks.

Q186. What is OpenAPI/Swagger security?

Answer: OpenAPI specifications define API schemas and security schemes (apiKey, OAuth2, OpenID), enabling automated security testing and enforcement of documented contracts.

Example: AWS API Gateway validates incoming requests against an OpenAPI schema, rejecting undocumented fields.

Q187. What is session management security?

Answer: Secure session management includes generating random session IDs, using secure and HttpOnly cookie flags, enforcing timeouts, and regenerating IDs after login.

Example: A cloud app sets session cookies with Secure, HttpOnly, SameSite=Strict flags and expires sessions after 30 minutes of inactivity.

Q188. What is broken authentication in cloud apps?

Answer: Broken authentication vulnerabilities (OWASP #7) include weak passwords, missing MFA, poor session management, and predictable tokens, allowing account takeover.

Example: Implementing AWS Cognito with MFA and account lockout after 5 failed attempts prevents brute force attacks.

Q189. What is software attestation?

Answer: Software attestation verifies that a software component has not been tampered with and is running in a trusted environment, using cryptographic signatures.

Example: SLSA framework ensures build provenance: signed attestation proves code was built from a specific commit by a trusted pipeline.

Q190. What is a service account security in cloud?

Answer: Service account security ensures cloud service accounts have minimal permissions, rotate credentials regularly, and are not shared between applications.

Example: Each microservice has its own GCP service account with only the permissions it needs; unused accounts are disabled.

Q191. What is a cloud-native application protection platform (CNAPP)?

Answer: CNAPP combines CSPM, CWPP, and CIEM capabilities to provide unified visibility and security for cloud-native applications from development to runtime.

Example: Wiz CNAPP identifies that a misconfigured ECR image with a critical CVE is running in production EKS with excessive IAM permissions.

Q192. What is dependency confusion attack?

Answer: A dependency confusion attack publishes a malicious package with the same name as an internal private package to public registries, tricking build systems into downloading the malicious version.

Example: An attacker publishes a package named 'company-utils' to npm; private registry scoping and version pinning prevent execution.

Q193. What is a canary deployment for security?

Answer: Canary deployments release new versions to a small subset of users first, limiting the blast radius of security issues in new code before full rollout.

Example: 5% of traffic is routed to a new API version; anomalous error rates trigger automatic rollback before full deployment.

Q194. What is security chaos engineering?

Answer: Security chaos engineering deliberately introduces security failures (e.g., disabling encryption, exposing credentials) in controlled experiments to test detection and response capabilities.

Example: Netflix's security chaos engineering team disables a WAF rule in staging to verify SIEM alerts fire within 2 minutes.

Q195. What is a software factory in cloud?

Answer: A software factory is an automated pipeline that produces secure, compliant software artefacts with built-in security scanning, signing, and SBOM generation.

Example: A DoD software factory uses GitLab, Tekton, and Anchore to produce signed container images with verified SBOMs for every release.

Q196. What is an API gateway vs a service mesh?

Answer: An API gateway handles north-south traffic (external to internal) with auth, rate limiting, and routing. A service mesh handles east-west traffic (service to service) with mTLS and observability.

Example: Kong API Gateway manages external API traffic; Istio service mesh secures internal microservice communication within the cluster.

Q197. What is secure coding training?

Answer: Secure coding training educates developers on common vulnerabilities (OWASP), secure design patterns, and language-specific security pitfalls to reduce security defects.

Example: Annual SANS secure coding training reduces SQLi defects by 60% in a development team's code review findings.

Q198. What is a web shell?

Answer: A web shell is a malicious script uploaded to a web server that gives an attacker remote code execution via the web, often exploiting file upload vulnerabilities.

Example: Restricting upload file types to images and storing uploads outside the webroot prevents web shell deployment.

Q199. What is API versioning and security?

Answer: API versioning maintains multiple API versions simultaneously; security requires that deprecated versions are decommissioned to prevent exploitation of unpatched old versions.

Example: An organisation deprecates API v1 (vulnerable to BOLA) and forces clients to migrate to hardened API v3.

Q200. What is security telemetry in cloud apps?

Answer: Security telemetry is the collection, analysis, and correlation of security-relevant data points from applications, infrastructure, and network for threat detection and response.

Example: Datadog APM captures trace data showing a spike in SQL error rates, indicating an SQLi attack on a microservice.

Domain 5: Cloud Security Operations

Q201. What is a Security Operations Centre (SOC) in cloud context?

Answer: A cloud SOC monitors, detects, and responds to security threats across cloud environments using SIEM, SOAR, and threat intelligence, staffed by security analysts.

Example: A 24/7 SOC monitors AWS GuardDuty findings, correlates with Splunk, and responds to incidents within defined SLAs.

Q202. What is SOAR (Security Orchestration, Automation, and Response)?

Answer: SOAR platforms automate repetitive security tasks, orchestrate tools, and provide playbooks to accelerate incident response and reduce analyst workload.

Example: A SOAR playbook automatically isolates an infected EC2 instance, captures memory, and notifies the IR team within 60 seconds of a GuardDuty finding.

Q203. What is threat intelligence in cloud security?

Answer: Threat intelligence is evidence-based knowledge about threats including indicators of compromise (IoCs), attacker TTPs, and vulnerabilities, used to proactively defend cloud environments.

Example: CrowdStrike threat intelligence feeds are integrated into SIEM rules to block known C2 IP addresses in AWS WAF automatically.

Q204. What is the MITRE ATT&CK; framework?

Answer: MITRE ATT&CK; is a knowledge base of adversary tactics and techniques based on real-world observations, used for threat detection, gap analysis, and red team planning.

Example: A SOC maps GuardDuty findings to MITRE ATT&CK; techniques to prioritise detection coverage gaps.

Q205. What is security incident management?

Answer: Security incident management is the structured process of identifying, classifying, containing, eradicating, recovering from, and documenting security incidents.

Example: A P1 incident (confirmed data breach) triggers CSIRT activation, legal notification, and a war room within 30 minutes per the IR plan.

Q206. What is a playbook in security operations?

Answer: A security playbook is a documented set of steps for responding to specific types of incidents (malware, data breach, DDoS), ensuring consistent and efficient response.

Example: A compromised IAM key playbook includes: disable key, revoke sessions, audit actions, rotate all keys, and notify security team.

Q207. What is mean time to detect (MTTD) and mean time to respond (MTTR)?

Answer: MTTD measures the average time from when a threat occurs to when it is detected. MTTR measures the average time from detection to full resolution. Both are key SOC metrics.

Example: Reducing MTTD from 72 hours to 4 hours by deploying UEBA significantly limits the blast radius of insider threats.

Q208. What is user entity and behaviour analytics (UEBA)?

Answer: UEBA uses machine learning to establish baselines of normal behaviour for users and entities, flagging deviations that may indicate insider threats or compromised accounts.

Example: UEBA detects an employee downloading 50GB of files at 3am—unusual for their role—triggering an insider threat investigation.

Q209. What is cloud threat hunting?

Answer: Threat hunting proactively searches cloud environments for hidden threats that evade automated detection, using hypothesis-driven investigations of logs and telemetry.

Example: A threat hunter queries CloudTrail for AssumeRole calls from unusual geographic regions, discovering a credential-based intrusion.

Q210. What is a tabletop exercise in cloud security?

Answer: A tabletop exercise is a discussion-based simulation of a security scenario (e.g., ransomware attack) to test and improve IR plans without real operational impact.

Example: The security team conducts a ransomware tabletop, discovering their DR plan has no procedure for cloud-based backup validation.

Q211. What is log management in cloud?

Answer: Log management involves collecting, storing, protecting, and analysing logs from cloud resources to support security monitoring, compliance, and forensics.

Example: AWS CloudTrail, VPC Flow Logs, and CloudWatch Logs are centralised in a separate security AWS account with immutable S3 storage.

Q212. What is log integrity in cloud?

Answer: Log integrity ensures that logs have not been tampered with after generation, using mechanisms like CloudTrail log file validation with SHA-256 hashes.

Example: AWS CloudTrail log file validation detects if an attacker deleted or modified API logs to cover their tracks.

Q213. What is anomaly detection in cloud security?

Answer: Anomaly detection uses statistical and ML models to identify deviations from normal behaviour in cloud traffic, API calls, and user activities.

Example: AWS GuardDuty uses anomaly detection to flag an EC2 instance making unusual outbound calls to known cryptocurrency mining pools.

Q214. What is a kill chain analysis?

Answer: Kill chain analysis maps an attack against the seven stages of the Lockheed Martin Cyber Kill Chain (Reconnaissance, Weaponisation, Delivery, Exploitation, Installation, C2, Actions on Objectives) to identify intervention points.

Example: Analysing a breach reveals the attacker used spear phishing (delivery) to install a backdoor (installation) before exfiltrating data.

Q215. What is digital forensics in cloud?

Answer: Cloud digital forensics involves collecting, preserving, and analysing digital evidence from cloud environments using volatile data capture, disk imaging, and log analysis.

Example: An AWS EC2 memory dump is captured before instance termination to preserve evidence of a running malware process.

Q216. What is chain of custody in cloud forensics?

Answer: Chain of custody documents the handling, transfer, and preservation of digital evidence from collection to court, ensuring its integrity and admissibility.

Example: SHA-256 hashes of evidence files are recorded at each transfer, maintaining chain of custody for an AWS data breach investigation.

Q217. What is cloud log retention?

Answer: Cloud log retention defines how long logs must be kept for security investigations, compliance, and legal requirements, balanced against storage cost.

Example: A financial firm retains CloudTrail logs for 7 years in S3 Glacier per SEC Rule 17a-4, with WORM protection.

Q218. What is a security baseline?

Answer: A security baseline is a minimum set of security controls that all cloud resources must meet, serving as the foundation for compliance and deviation detection.

Example: An AWS Security Hub standard checks all accounts against the AWS Foundational Security Best Practices baseline.

Q219. What is continuous compliance monitoring?

Answer: Continuous compliance monitoring automatically checks cloud configurations against compliance frameworks in real time, alerting on drift and enabling automated remediation.

Example: AWS Config Rules continuously check that S3 buckets have server-side encryption enabled, auto-remediating if disabled.

Q220. What is a cloud security dashboard?

Answer: A cloud security dashboard provides a centralised visual overview of security posture, active alerts, compliance status, and key metrics for security leaders and analysts.

Example: AWS Security Hub dashboard shows a consolidated security score and lists all critical findings across accounts and services.

Q221. What is evidence preservation in cloud incidents?

Answer: Evidence preservation captures volatile data (memory, running processes, network connections) before shutdown, creates forensic disk images, and locks down logs to prevent tampering.

Example: Before terminating a compromised EC2 instance, responders use AWS SSM to run a memory capture and isolate it in a forensic VPC.

Q222. What is a root cause analysis (RCA) in cloud security?

Answer: RCA identifies the fundamental cause of a security incident rather than just treating symptoms, enabling permanent fixes to prevent recurrence.

Example: RCA of an S3 data breach reveals the root cause was a missing bucket policy in the IaC template, leading to a policy-as-code fix.

Q223. What is patch Tuesday and cloud patching cadence?

Answer: Patch Tuesday is Microsoft's monthly security update cycle. Cloud environments should apply critical patches within 24-72 hours and high severity within 7 days per security policy.

Example: AWS Systems Manager Patch Manager automatically applies Patch Tuesday updates to Windows EC2 instances within 24 hours.

Q224. What is a service health dashboard and its security relevance?

Answer: Cloud providers' service health dashboards report outages and incidents. Security teams monitor them to distinguish provider incidents from attacks during response.

Example: During a suspected DDoS, checking AWS Service Health Dashboard confirms it is a provider outage, not an attack, preventing false incident escalation.

Q225. What is change management in cloud security?

Answer: Change management controls how cloud infrastructure changes are proposed, approved, tested, and deployed, preventing unauthorised changes that could introduce vulnerabilities.

Example: All Terraform changes require peer review, security scan, and change advisory board approval before production deployment.

Q226. What is purple teaming?

Answer: Purple teaming combines red team (attackers) and blue team (defenders) working together to improve detection and response through shared knowledge and real-time collaboration.

Example: Red team attacks a cloud environment while blue team tunes SIEM rules in real time, rapidly improving detection coverage.

Q227. What is security metrics and KPIs for cloud?

Answer: Cloud security KPIs include patch compliance %, mean time to detect/respond, open critical vulnerability count, failed login rate, and compliance score.

Example: Monthly security report shows 98% patch compliance, MTTD of 4 hours, and zero critical open findings, meeting SLA targets.

Q228. What is a managed detection and response (MDR) service?

Answer: MDR is a managed security service providing 24/7 threat detection, investigation, and response for cloud environments, outsourcing SOC capabilities.

Example: A startup uses CrowdStrike MDR to get 24/7 cloud security coverage without hiring a full SOC team.

Q229. What is deception-based detection?

Answer: Deception-based detection deploys decoy tokens, fake credentials, and honeypots to detect attackers who access these traps, providing high-fidelity alerts.

Example: AWS canary tokens (fake access keys) placed in config files alert immediately when an attacker tries to use them.

Q230. What is forensic readiness in cloud?

Answer: Forensic readiness is proactively configuring cloud environments to maximise the quality and availability of evidence before an incident occurs.

Example: Enabling CloudTrail with log validation, VPC Flow Logs, and S3 access logging across all accounts ensures forensic readiness.

Q231. What is a cloud-native SIEM?

Answer: A cloud-native SIEM is built on cloud infrastructure, providing elastic scalability, pay-per-use pricing, and native integration with cloud services.

Example: Microsoft Sentinel is a cloud-native SIEM that natively ingests Azure AD, Office 365, and AWS logs without complex connectors.

Q232. What is security event correlation?

Answer: Security event correlation combines related events from multiple sources to identify attack patterns that individual events would not reveal.

Example: Correlating a failed MFA attempt, new IAM user creation, and S3 data download reveals a credential compromise sequence.

Q233. What is threat emulation?

Answer: Threat emulation replicates known adversary TTPs (using tools like Atomic Red Team or CALDERA) to test whether security controls detect specific attack techniques.

Example: Running MITRE ATT&CK; technique T1078 (Valid Accounts) emulation verifies GuardDuty detects abnormal IAM key usage.

Q234. What is cloud security awareness training?

Answer: Cloud security awareness training educates all staff on cloud-specific risks including misconfiguration, phishing targeting cloud credentials, and shadow IT.

Example: Annual phishing simulation targeting AWS console credentials reduces click rate from 30% to 5% after training.

Q235. What is a cloud security architecture review?

Answer: A cloud security architecture review assesses whether cloud designs meet security requirements including network security, IAM, encryption, resilience, and compliance.

Example: AWS Well-Architected Tool security review identifies that no MFA is enforced on IAM accounts, prompting immediate remediation.

Q236. What is operational security (OpSec) in cloud?

Answer: OpSec protects sensitive operational information about cloud security posture, incident response procedures, and defensive controls from adversary intelligence gathering.

Example: A company uses separate communication channels for IR activities to prevent an insider from monitoring the response to their own attack.

Q237. What is a cloud security programme?

Answer: A cloud security programme is a comprehensive, structured approach to managing cloud security including strategy, governance, risk, compliance, operations, and architecture.

Example: A CISO builds a cloud security programme aligned to ISO 27017, CSA CCM, and NIST CSF covering all 6 pillars.

Q238. What is security SLA management in cloud?

Answer: Security SLA management tracks and reports against contractual security commitments including incident response times, availability, and audit rights.

Example: Monthly SLA report confirms vendor met 99.9% uptime, <4hr incident response, and no SLA breaches for the quarter.

Q239. What is a cyber fusion centre?

Answer: A cyber fusion centre integrates threat intelligence, SOC operations, vulnerability management, and incident response into a unified team for faster, coordinated defence.

Example: A bank's cyber fusion centre combines threat intel and IR teams, reducing MTTD by 50% through intelligence-driven hunting.

Q240. What is cloud security posture management (CSPM)?

Answer: CSPM continuously monitors cloud configurations for misconfigurations, compliance violations, and security risks across IaaS, PaaS, and SaaS environments.

Example: Palo Alto Prisma Cloud CSPM identifies 47 critical misconfigurations across AWS accounts and provides one-click remediation.

Q241. What is identity threat detection and response (ITDR)?

Answer: ITDR focuses on detecting and responding to attacks targeting identity infrastructure (AD, IAM, SSO) which are increasingly the primary cloud attack vector.

Example: CrowdStrike Falcon Identity Protection detects Pass-the-Hash attacks against hybrid AD/Azure AD environments.

Q242. What is cloud workload security?

Answer: Cloud workload security protects VMs, containers, and functions through vulnerability management, runtime protection, and integrity monitoring.

Example: AWS Inspector continuously assesses EC2 and Lambda workloads for CVEs and network accessibility issues.

Q243. What is security data lake?

Answer: A security data lake centralises security telemetry at scale in low-cost object storage, enabling long-term retention and advanced analytics.

Example: Amazon Security Lake normalises all AWS security logs into OCSF format in S3 for centralised analysis.

Q244. What is extended detection and response (XDR)?

Answer: XDR integrates and correlates data across endpoints, networks, cloud, and identities to provide unified threat detection and automated response.

Example: Microsoft Defender XDR correlates Azure AD anomaly with an Intune-managed device alert and a cloud workload finding to identify a complete attack chain.

Q245. What is a cloud incident response retainer?

Answer: An IR retainer is a pre-negotiated agreement with a security firm for emergency incident response services, ensuring rapid expert support during a major cloud breach.

Example: A company retains Mandiant for cloud IR support; contractual 4-hour SLA ensures rapid expert response to a ransomware event.

Q246. What is red team vs blue team in cloud?

Answer: Red team simulates attackers against cloud infrastructure; blue team defends. Their exercises test and improve detection, response, and resilience.

Example: Red team compromises a cloud environment using SSRF→IMDS→privilege escalation; blue team improves detection based on findings.

Q247. What is a post-incident review (PIR)?

Answer: A PIR is a structured review after a security incident to identify what happened, why controls failed, and what improvements will prevent recurrence.

Example: After an S3 data exposure, PIR identifies that the IaC code review process missed a `public_access_block` setting, leading to a new automated check.

Q248. What is cloud security benchmarking?

Answer: Cloud security benchmarking compares an organisation's cloud security maturity against industry peers and best practices to identify areas for investment.

Example: CIS Controls self-assessment benchmarks a company at maturity level 2, with a roadmap to reach level 4 within 18 months.

Q249. What is automated remediation in cloud security?

Answer: Automated remediation uses scripts, Lambda functions, or SOAR playbooks to automatically fix security misconfigurations without human intervention.

Example: An AWS Config rule auto-remediates public S3 buckets by calling a Lambda that enables block public access settings.

Q250. What is a cloud security maturity model?

Answer: A cloud security maturity model assesses an organisation's cloud security capabilities across dimensions like governance, architecture, operations, and culture at defined maturity levels.

Example: CSA STAR self-assessment places an organisation at Level 2; a roadmap targets Level 3 STAR Certification within one year.

Domain 6: Legal, Risk & Compliance

Q251. What is GDPR and how does it apply to cloud?

Answer: GDPR (General Data Protection Regulation) is an EU regulation governing the processing of EU citizens' personal data. Cloud providers must act as data processors with DPAs, and data must be protected with appropriate controls.

Example: An e-commerce company using AWS must sign a DPA with AWS and ensure EU customer data does not leave the EU without appropriate safeguards.

Q252. What is HIPAA and its cloud implications?

Answer: HIPAA (Health Insurance Portability and Accountability Act) protects US healthcare data (PHI). Cloud deployments processing PHI require a Business Associate Agreement (BAA) with the cloud provider.

Example: A hospital must sign a BAA with AWS before storing patient data in S3, ensuring AWS's HIPAA compliance obligations.

Q253. What is PCI DSS and cloud?

Answer: PCI DSS (Payment Card Industry Data Security Standard) protects cardholder data. Cloud environments in scope for PCI must implement controls including encryption, access control, and penetration testing.

Example: An e-commerce site processes credit cards on an AWS environment scoped for PCI DSS Level 1 compliance, validated by a QSA.

Q254. What is SOC 2 compliance?

Answer: SOC 2 is an auditing framework for service organisations based on the Trust Services Criteria: Security, Availability, Processing Integrity, Confidentiality, and Privacy.

Example: A SaaS company obtains SOC 2 Type 2 certification by having an auditor verify security controls operated effectively for 6 months.

Q255. What is ISO 27001?

Answer: ISO 27001 is an international standard for information security management systems (ISMS), providing a systematic approach to managing sensitive information security risks.

Example: A cloud provider obtains ISO 27001 certification, demonstrating its ISMS meets international security management standards.

Q256. What is ISO 27017?

Answer: ISO 27017 is a code of practice for information security controls in cloud services, extending ISO 27001 with cloud-specific guidance for both providers and customers.

Example: A cloud provider implements ISO 27017 controls for virtual machine hardening and multi-tenancy segregation beyond base ISO 27001 requirements.

Q257. What is ISO 27018?

Answer: ISO 27018 is a code of practice for protection of personally identifiable information (PII) in public clouds, addressing cloud-specific PII processing risks.

Example: A cloud provider certified to ISO 27018 demonstrates it will not use customer data for advertising and will notify customers of data requests.

Q258. What is FedRAMP?

Answer: FedRAMP (Federal Risk and Authorisation Management Programme) is a US government programme providing a standardised security assessment and authorisation process for cloud services used by federal agencies.

Example: A cloud vendor obtains FedRAMP High authorisation to provide cloud services to US Department of Defence agencies.

Q259. What is CCPA (California Consumer Privacy Act)?

Answer: CCPA gives California residents rights over their personal data including the right to know, delete, and opt out of sale. It applies to businesses meeting certain thresholds.

Example: A company implements a CCPA opt-out mechanism in its cloud-hosted website allowing California users to opt out of data sale.

Q260. What is risk management framework (RMF)?

Answer: The NIST RMF is a structured process for integrating security and risk management into system development lifecycle, including Categorise, Select, Implement, Assess, Authorise, and Monitor.

Example: A federal agency uses NIST RMF to authorise an AWS GovCloud deployment, completing all six steps before go-live.

Q261. What is a risk register?

Answer: A risk register is a document that records identified risks, their likelihood, impact, owner, and mitigation status, used to manage and track cloud security risks.

Example: A cloud risk register records the risk of 'public S3 bucket exposure' with High impact, remediated by bucket policy enforcement.

Q262. What is qualitative vs quantitative risk assessment?

Answer: Qualitative risk assessment uses subjective scales (High/Medium/Low) for likelihood and impact. Quantitative uses monetary values ($ALE = ARO \times SLE$) to calculate financial risk exposure.

Example: Quantitative analysis shows a data breach has ALE of \$2M, justifying \$500K annual investment in cloud DLP controls.

Q263. What is a business impact analysis (BIA)?

Answer: A BIA identifies critical business functions, their dependencies, and the financial/operational impact of disruption, informing RTO/RPO requirements.

Example: BIA reveals the payment processing system has a \$100K/hour downtime cost, requiring an RTO of 30 minutes for that AWS service.

Q264. What is cloud compliance vs security?

Answer: Compliance ensures adherence to specific regulations and standards (PCI, HIPAA); security encompasses broader risk reduction. Compliance is necessary but not sufficient for security.

Example: A PCI DSS compliant organisation may still suffer a breach if security controls only meet minimum compliance requirements without addressing emerging threats.

Q265. What is an audit right in cloud contracts?

Answer: Audit rights allow cloud customers (or their auditors) to inspect cloud provider security controls, certifications, and compliance evidence.

Example: A financial regulator requires the ability to audit a cloud provider's physical data centre controls; the provider offers ISO 27001 certification as a substitute.

Q266. What is a data protection officer (DPO)?

Answer: Under GDPR, organisations processing large amounts of personal data must appoint a DPO responsible for data protection strategy and compliance.

Example: A multinational company appoints a DPO who oversees GDPR compliance for all cloud-hosted personal data processing activities.

Q267. What is data breach liability in cloud?

Answer: Data breach liability depends on the shared responsibility model; customers are typically liable for data protection failures within their scope, even if hosted on a compliant cloud provider.

Example: An AWS customer's exposed S3 bucket causes a breach; the customer bears GDPR liability even though AWS infrastructure was secure.

Q268. What is e-discovery in cloud?

Answer: E-discovery is the legal process of identifying, collecting, and preserving electronically stored information for litigation. Cloud environments must support legal holds and data preservation.

Example: AWS S3 Object Lock (WORM) preserves documents under litigation hold, preventing deletion or modification.

Q269. What is a legal hold in cloud?

Answer: A legal hold is an instruction to preserve data that may be relevant to anticipated or ongoing litigation, overriding normal retention and deletion schedules.

Example: General Counsel issues a legal hold on all AWS CloudTrail logs related to a whistleblower investigation, preventing scheduled deletion.

Q270. What is regulatory mapping in cloud?

Answer: Regulatory mapping identifies which regulations apply to cloud workloads and maps their requirements to specific technical and administrative controls.

Example: A healthcare cloud team maps HIPAA Security Rule requirements to AWS controls: encryption (§164.312(a)(2)(iv)), audit logs (§164.312(b)).

Q271. What is cloud contract management?

Answer: Cloud contract management involves negotiating, reviewing, and managing cloud service agreements to ensure security, compliance, data protection, and exit clauses are adequately addressed.

Example: Legal review of an Azure EA contract ensures it includes GDPR DPA, adequate SLAs, audit rights, and data portability clauses.

Q272. What is supply chain risk management (SCRM)?

Answer: SCRM identifies and mitigates risks from third-party vendors, suppliers, and partners in the cloud supply chain who may introduce security vulnerabilities.

Example: A company assesses cloud software vendors using NIST SP 800-161 SCRM framework before approving them for production use.

Q273. What is the right to erasure under GDPR?

Answer: GDPR Article 17 gives individuals the right to have their personal data deleted when it is no longer necessary, consent is withdrawn, or processing is unlawful.

Example: A user requests deletion of their account; the platform must delete their PII from all cloud databases, backups, and logs within 30 days.

Q274. What is data transfer mechanism under GDPR?

Answer: GDPR restricts transfer of personal data outside the EU/EEA. Legal mechanisms include Standard Contractual Clauses (SCCs), Binding Corporate Rules, and adequacy decisions.

Example: A company uses SCCs to legally transfer EU customer data to AWS US-East-1 regions for processing.

Q275. What is the Cloud Security Alliance STAR programme?

Answer: CSA STAR (Security, Trust, Assurance and Risk) is a programme for cloud providers to demonstrate security assurance through self-assessment, third-party audits, and continuous monitoring.

Example: A cloud provider achieves CSA STAR Level 2 certification, demonstrating independent third-party audit of its security controls.

Q276. What is third-party risk management (TPRM) in cloud?

Answer: TPRM assesses and manages security risks from third-party cloud services, SaaS applications, and outsourced functions used by the organisation.

Example: Annual TPRM reviews assess all SaaS vendors' SOC 2 reports, security questionnaires, and penetration test results.

Q277. What is the principle of purpose limitation under GDPR?

Answer: Purpose limitation requires that personal data collected for one specific purpose is not used for other incompatible purposes without additional consent.

Example: Customer email addresses collected for order confirmation cannot be used for marketing without separate opt-in consent.

Q278. What is an information security management system (ISMS)?

Answer: An ISMS is a systematic framework of policies, processes, and controls for managing information security risks, certified to ISO 27001.

Example: A cloud company implements an ISMS covering 114 ISO 27001 controls, achieving certification after a successful external audit.

Q279. What is NIST Cybersecurity Framework (CSF)?

Answer: NIST CSF provides a framework for improving critical infrastructure cybersecurity across five functions: Identify, Protect, Detect, Respond, and Recover.

Example: A utility company maps their AWS security programme to NIST CSF, identifying gaps in the Detect and Respond functions.

Q280. What is cloud security contractual obligations?

Answer: Cloud contracts should include security requirements covering data encryption, incident notification timelines, audit rights, data deletion, and liability allocation.

Example: A GDPR-compliant cloud contract requires breach notification within 72 hours, AES-256 encryption, and annual penetration testing.

Q281. What is regulatory change management in cloud?

Answer: Regulatory change management monitors changes in applicable laws and standards, assessing their impact on cloud controls and implementing required updates.

Example: When GDPR updated SCCs in 2021, the legal team updated all 47 cloud vendor agreements within the 18-month transition period.

Q282. What is cloud insurance (cyber insurance)?

Answer: Cyber insurance covers financial losses from cloud security incidents including breach response, legal fees, regulatory fines, and business interruption.

Example: A company's cyber insurance policy covers up to \$10M in GDPR fines and breach response costs, requiring cloud security minimum controls.

Q283. What is ENISA's role in cloud security?

Answer: ENISA (EU Agency for Cybersecurity) provides cloud security guidance, risk assessments, and certification frameworks for EU cloud services under the EUCS scheme.

Example: ENISA's EUCS cloud security certification scheme provides three assurance levels for cloud services in EU member states.

Q284. What is data localisation?

Answer: Data localisation laws require that certain types of data (healthcare, financial, government) be stored and processed within the country's borders.

Example: Russia's Federal Law 242-FZ requires all Russian personal data to be stored on servers physically located within Russia.

Q285. What is cloud exit strategy?

Answer: A cloud exit strategy defines how an organisation will migrate data and applications from a cloud provider, ensuring continuity and data portability without vendor lock-in.

Example: An exit strategy specifies that all data can be exported in standard formats within 90 days, tested annually through mock migration exercises.

Q286. What is an acceptable use policy (AUP) for cloud?

Answer: An AUP defines permitted and prohibited uses of cloud resources by employees, contractors, and users, forming a key governance and legal compliance document.

Example: The AUP prohibits storing personal data in unapproved cloud services (shadow IT) and requires secure deletion before releasing cloud resources.

Q287. What is privacy by design?

Answer: Privacy by design is the principle that privacy protections should be built into systems and processes from the outset rather than added as an afterthought, a GDPR requirement.

Example: A new cloud application is designed with data minimisation, encryption, and consent management built in from day one of development.

Q288. What is cloud accountability under GDPR?

Answer: GDPR accountability principle requires organisations to not just comply but be able to demonstrate compliance through policies, records, DPIAs, and audit trails.

Example: A company maintains GDPR Records of Processing Activities (RoPA) for all AWS-hosted processing, auditable by data protection authorities.

Q289. What is security assurance in cloud?

Answer: Security assurance provides confidence that cloud security controls are implemented correctly and operating effectively, through testing, certification, and continuous monitoring.

Example: Annual penetration testing and quarterly CSPM scans provide assurance that AWS controls meet PCI DSS requirements.

Q290. What is a cloud trust model?

Answer: A cloud trust model defines the level of trust placed in cloud providers and their security certifications as a basis for risk-based compliance decisions.

Example: A company's trust model accepts AWS SOC 2 Type 2 and ISO 27001 as sufficient assurance without independent audit rights for standard workloads.

Q291. What is privacy shield and its current status?

Answer: Privacy Shield was a framework for EU-US data transfers invalidated by the Schrems II ruling in 2020. It has been replaced by the EU-US Data Privacy Framework in 2023.

Example: After Privacy Shield's invalidation, companies switched to Standard Contractual Clauses; the 2023 Data Privacy Framework now provides an updated legal basis.

Q292. What is the NIS2 Directive?

Answer: NIS2 (Network and Information Security Directive 2) is an EU directive strengthening cybersecurity requirements for critical infrastructure and important entities, effective October 2024.

Example: Cloud providers classified as 'important entities' under NIS2 must implement supply chain security measures and report incidents within 24 hours.

Q293. What is the Cyber Resilience Act (CRA)?

Answer: The EU Cyber Resilience Act (2024) requires products with digital elements sold in the EU to meet mandatory cybersecurity requirements throughout their lifecycle.

Example: IoT device manufacturers must provide security updates for their product's expected lifetime and report vulnerabilities under the CRA.

Q294. What is a data impact threshold assessment?

Answer: A data impact threshold assessment determines whether a full DPIA is required for a processing activity based on criteria like scale, sensitivity, and novel technologies.

Example: Using facial recognition on employee access data triggers a mandatory DPIA under GDPR Article 35 due to biometric data processing.

Q295. What is the concept of data controller vs data processor under GDPR?

Answer: A data controller determines the purposes and means of processing personal data. A data processor processes data on behalf of the controller. Both have distinct GDPR obligations.

Example: A company is the data controller for employee HR data; Workday (SaaS HR system on AWS) is the data processor.

Q296. What is a whistleblower protection consideration in cloud?

Answer: Cloud systems processing whistleblower reports must ensure strong anonymity, data protection, and limited access to protect reporters from retaliation.

Example: A secure cloud-based whistleblower platform uses end-to-end encryption and anonymisation, with access restricted to the audit committee only.

Q297. What is data minimisation in cloud architecture?

Answer: Data minimisation means architecturally designing cloud systems to collect and process only the data strictly necessary, reducing privacy risk and compliance scope.

Example: A cloud analytics system anonymises personal data at the point of collection, removing PII from the analytics pipeline entirely.

Q298. What is the role of the Board in cloud security governance?

Answer: The Board provides oversight of cloud security strategy, approves risk appetite, ensures adequate resourcing, and receives regular security performance reports.

Example: The Board receives a quarterly cloud security risk report including CSPM scores, incident trends, and compliance status for informed oversight.

Q299. What is cloud security due diligence in mergers and acquisitions?

Answer: Cloud security due diligence during M&A; assesses the target's cloud security posture, compliance status, outstanding vulnerabilities, and historical incidents.

Example: During acquisition, a tech company discovers the target has an unpatched critical CVE on their production AWS environment, delaying deal closure.

Q300. What is the concept of security as an enabler in cloud business?

Answer: Security as an enabler positions cloud security controls not as barriers but as business differentiators that build customer trust, enable compliance, and accelerate cloud adoption.

Example: A SaaS company's SOC 2 Type 2 and ISO 27001 certifications win enterprise contracts that require security assurance, directly generating revenue.